

MAPEO DETALLADO: PREGUNTAS DE ENCUESTA → REQUISITOS NORMATIVOS

Matriz de Trazabilidad NIST CSF 2.0, ENS, NIS2, GDPR, ISO 27001

Versión: 1.0 | **Fecha:** Enero 2026 | **Cobertura:** 60+ preguntas en 5+ marcos normativos

LEYENDA DE NORMAS

Sigla	Norma Completa	Ámbito	Referencia
NIST CSF 2.0	NIST Cybersecurity Framework v2.0 (Feb 2024)	Global, voluntario	https://nvlpubs.nist.gov/nistpubs/CSWP/NIST.CSWP.29.spa.pdf
ENS	Esquema Nacional de Seguridad RD 311/2022	España Admin. Pública	https://www.ccn-cert.cni.es/
NIS2	Directiva 2022/2555/EU (Transposición 2024-2026)	UE, 18 sectores	Directiva oficial EUR-Lex
GDPR	Reglamento (UE) 2016/679	UE, todas orgs	RGPD artículos clave
ISO 27001	ISO/IEC 27001:2022	Global, certificable	ISO/IEC 27001 Anexo A (14 temas, 93 controles)
ACET	Automated Cybersecurity Evaluation Toolbox (NCUA)	Instituciones financieras	NCUA User Guide
OWASP	Open Web Application Security Project Top 10	Aplicaciones web	OWASP.org

BLOQUE I: GOBIERNO Y ESTRATEGIA (GV)

P1.1.1 - Política de Ciberseguridad Formalizada

Norma	Artículo/ Requisito	Requisitos Específicos	Nivel ENS	Mapeo NIST CSF 2.0
NIST CSF 2.0	GV.PO-01	Política aprobada, comunicada, revisada anualmente	N/A	Govern – Policy, Risk & Oversight
GDPR	Art. 5, 32	Principio de Responsabilidad (Accountability); medidas técnicas y organizativas documentadas	BÁSICA	Establish & implement data protection policies
ENS	Política de Seguridad	Documento de dirección, niveles BÁSICA/MEDIA/ ALTA (L2-L4)	L2+	Cumplimiento Art. 5.1 RGPD
NIS2	Art. 17, 18	Política de ciberseguridad, gestión riesgos, roles definidos	Obligatorio	Governance framework
ISO 27001	A.5.1	Información de seguridad, políticas de seguridad de la información	Obligatorio	A.5 Organizational Controls

Evidencia Aceptable:

- ✓ Documento de Política digitalizado, aprobado por Junta/Órgano Ejecutivo, fecha de aprobación documentada
- ✓ Evidencia de comunicación a todos los empleados (ej. email, training completion)
- ✓ Última revisión fecha (máximo 12 meses atrás)
- ✓ Mención explícita de CISO/responsable designado

P1.1.2 - Designación Formal de CISO

Norma	Artículo/ Requisito	Requisitos Específicos	Nivel ENS	Mapeo NIST CSF 2.0
NIST CSF 2.0	GV.OC-01	Roles & responsabilidades formalmente asignados	N/A	Organize → Governance
GDPR	Art. 37-38	Delegado de Protección de Datos (DPD) obligatorio para administraciones públicas; rol de ciberseguridad para empresas	BÁSICA	Designate data controller roles
ENS	Función de Responsable de Seguridad	Responsable de Seguridad de Información (RSI), acceso dirección	L2+	A.6.1.3 Responsabilidades
NIS2	Art. 18 (Gobernanza)	Persona responsable ciberseguridad con autoridad, acceso Junta Directiva (CISO/CSO)	Obligatorio	Board-level cybersecurity reporting
ISO 27001	A.6.1	Responsabilidades de gestión de seguridad, CISO designado	Obligatorio	A.6 Organizational Controls

Evidencia Aceptable:

- ✓ Orden/Decreto/Resolución formal designando CISO con nombre, fecha
- ✓ Job description CISO mencionando acceso directo a CEO/Junta
- ✓ Reporting line (organigrama) mostrando CISO reporte CEO, no bajo IT Manager
- ✓ Presupuesto independiente para CISO (opcional pero positivo)

P1.2.1 - Evaluaciones de Riesgos Formales Anuales

Norma	Artículo/ Requisito	Requisitos Específicos	Nivel ENS	Mapeo NIST CSF 2.0
NIST CSF 2.0	ID.RA-01, GV.RM-01	Evaluación riesgos formal, documentada, actualizada regularmente	N/A	Identify Risk, Govern Risk
GDPR	Art. 5(1)(f), 32	Evaluación riesgos a protección de datos; análisis de riesgos antes procesos nuevos	BÁSICA	Data Protection Impact Assessment (DPIA)
ENS	Art. 42-49 (Análisis Riesgos)	Metodología ISO 27005 o NIST SP 800-30; anual obligatorio; documentar en registro riesgos	L3+	Risk evaluation cuantificada
NIS2	Art. 19-20	Evaluación riesgos periódica; auditorías internas; riesgos documentados	Obligatorio	Risk management framework
ISO 27001	A.12.6, A.18	Evaluación riesgos información seguridad; metodología formales	Obligatorio	A.12.6 Management of technical & organizational change

Evidencia Aceptable:

- ✓ Documento formal de Evaluación Riesgos 2025 (anual mínimo)
- ✓ Metodología explícita: FAIR, ISO 27005, NIST SP 800-30 documentada
- ✓ Identificación de activos, amenazas, vulnerabilidades, impacto
- ✓ Matriz de riesgos: probabilidad × impacto → prioridad
- ✓ Acciones mitigación asociadas a cada riesgo
- ✓ Firma de aprobación por CISO/Dirección

BLOQUE II: IDENTIFICAR (ID)

P2.1.1 - Catálogo Master de Activos (CMDB)

Norma	Artículo/ Requisito	Requisitos Específicos	Nivel ENS	Mapeo NIST CSF 2.0
NIST CSF 2.0	ID.AM-01, ID.AM-02	Inventario activos sistemas, datos; catalogado por criticidad	N/A	Identify & Inventory Assets
GDPR	Art. 32	Registro de tratamiento de datos (ROPA), ubicación datos, categorías	BÁSICA	Data inventory mapping
ENS	Gestión de Activos	Inventario activos, clasificación, propietario, ubicación; actualización permanente	L3+	A.8.1 Asset classification
NIS2	Art. 19	Inventario activos críticos, sistemas esenciales, dependencias	Obligatorio	Asset criticality assessment
ISO 27001	A.8.1	Clasificación información y activos; inventario actualizado	Obligatorio	A.8 Asset Management

Evidencia Aceptable:

- ✓ Base de datos CMDB con: servidor/app name, propietario, clasificación, RTO/RPO, ubicación
- ✓ Cobertura >90% del estate IT
- ✓ Actualización automatizada o trimestral manual
- ✓ Mapeo de dependencias entre activos (app A depende de BD B)

BLOQUE III: PROTEGER (PR)

P3.1.1 - Multi-Factor Authentication (MFA)

Norma	Artículo/ Requisito	Requisitos Específicos	Nivel ENS	Mapeo NIST CSF 2.0
NIST CSF 2.0	PR.AC-01, PR.AC-07	Control de acceso; autenticación multi-factor para acceso privilegiado	N/A	Protect → Access Control
GDPR	Art. 32(b)	Medidas técnicas para control acceso; pseudonimización	MEDIA	Strong authentication
ENS	Autenticación	MFA obligatorio nivel ALTA; nivel MEDIA recomendado; TLS 1.2+	L3/L4	PR.AC-01 Access control mechanisms
NIS2	Art. 20(2)	Autenticación multifactor, en particular para acceso remoto; requisito crítico	Obligatorio	Mandatory for critical systems
ISO 27001	A.9.2	Control de acceso usuario; autenticación; mecanismos de autenticación	Obligatorio	A.9 Access Control

Evidencia Aceptable:

- ✓ Lista de sistemas críticos con MFA habilitado (>85%)
- ✓ Configuración MFA: SMS, authenticator, hardware keys
- ✓ Política MFA documentada, excepciones autorizadas y auditadas
- ✓ Logs de MFA fallos/éxitos registrados 6+ meses

P3.1.3 - Revisiones Periódicas de Acceso

Norma	Artículo/ Requisito	Requisitos Específicos	Nivel ENS	Mapeo NIST CSF 2.0
NIST CSF 2.0	PR.AC-04	Revisión de acceso usuario periódicamente; principio least privilege	N/A	Access review & de-provisioning
GDPR	Art. 32	Garantizar que acceso se limita a necesario (LPP)	BÁSICA	Principle of least privilege
ENS	Control de Acceso	Revisión acceso anual (L2), trimestral (L3), mensual (L4)	L2/L3/L4	PR.AC-04 Access re-certification
NIS2	Art. 19	Monitoreo acceso; revisiones de autorización	Obligatorio	Continuous access reviews
ISO 27001	A.9.2.5	Revisión derechos acceso usuario; al menos anual	Obligatorio	A.9.2.5 Access rights review

Evidencia Aceptable:

- ✓ Procedimiento formal de Access Review documentado
- ✓ Calendario establecido (ej: Q1=Finanzas, Q2=IT, Q3=RH, Q4=Otros)
- ✓ Certificaciones de propietarios de sistemas: "Acceso de Juan García aún justificado: SÍ"
- ✓ Registro de accesos revocados vs. certificados
- ✓ Target: >80% cobertura revisada en período

P3.2.1 - Cifrado de Datos en Tránsito y Reposo

Norma	Artículo/ Requisito	Requisitos Específicos	Nivel ENS	Mapeo NIST CSF 2.0
NIST CSF 2.0	PR.DS-02, PR.DS-01	Cifrado datos sensibles; almacenamiento seguro	N/A	Protect Data at Rest & in Transit
GDPR	Art. 32(1)(a)	Cifrado como pseudonimización en transmisión, almacenaje	MEDIA	Encryption mandatory
ENS	Cifrado	Criptografía: TLS 1.2+, AES-256; obligatorio L3/L4; nivel MEDIA recomendado	L3/L4	PR.DS-02 Data encryption in transit
NIS2	Art. 20	Cifrado datos, protección integridad; técnicas criptográficas reconocidas	Obligatorio	Cryptographic controls
ISO 27001	A.10.1.1, A.18.1.3	Cifrado información sensible; criptografía implementada	Obligatorio	A.10 Cryptography

Evidencia Aceptable:

- ✓ Inventario sistemas: cifrado en tránsito (TLS 1.2+) SÍ/NO
- ✓ Inventario datos sensibles: cifrado en reposo (AES-256) SÍ/NO
- ✓ Certificados SSL/TLS validos, no vencidos (auditados)
- ✓ Política gestión claves: rotación, backup, acceso
- ✓ Excepción de sistemas NO cifrados autorizada por CISO (excepciones <10%)

P3.4.1 - Capacitación en Seguridad Anual

Norma	Artículo/ Requisito	Requisitos Específicos	Nivel ENS	Mapeo NIST CSF 2.0
NIST CSF 2.0	PR.AT-01	Conciencia seguridad; capacitación periódica	N/A	Protect – Awareness & Training
GDPR	Art. 32(2)(c)	Garantizar comprensión medidas seguridad; formación regular	BÁSICA	Regular training mandatory
ENS	Concienciación	Capacitación anual mínimo; documentada; >80% participación	L2/L3	PR.AT-01 Personnel awareness training
NIS2	Art. 20(2)	Formación ciberseguridad personal; conciencia de amenazas	Obligatorio	Mandatory for all staff
ISO 27001	A.6.2	Competencia; capacitación seguridad información	Obligatorio	A.6 Organizational Controls

Evidencia Aceptable:

- ✓ Certificado de capacitación de cada empleado (año actual)
- ✓ Contenido mínimo: phishing, passwords, data classification, incident reporting
- ✓ Tasa de completación: >95%
- ✓ Pre/post assessment de conocimiento (opcional pero positivo)
- ✓ Registro de asistencia o certificados online

BLOQUE IV: DETECTAR (DE)

P4.1.1 - SIEM Centralizado

Norma	Artículo/ Requisito	Requisitos Específicos	Nivel ENS	Mapeo NIST CSF 2.0
NIST CSF 2.0	DE.AE-01	Monitoreo detecta incidentes; correlación eventos	N/A	Detect → Anomalies & Events
GDPR	Art. 32(1)(b), 33	Capacidad notificación incidentes; logging detección	BÁSICA	Incident detection logging
ENS	Monitoreo	Monitoreo centralizado logs (SIEM); auditoría eventos; 90+ días retención	L3/L4	DE.AE-01 Network monitoring
NIS2	Art. 19, 21	Monitoreo seguridad red; detección intrusión; logs centralizados	Obligatorio	SIEM & centralized logging
ISO 27001	A.12.4.1	Grabación eventos aplicación; logs centralizados; análisis	Obligatorio	A.12.4 Event logging

Evidencia Aceptable:

- ✓ SIEM solución (Splunk, ELK, Azure Sentinel, etc.) en producción
- ✓ Fuentes integradas: firewall, endpoints, aplicaciones, bases datos, identidad (>85%)
- ✓ Almacenamiento logs: >90 días searchable, >1 año archive
- ✓ Correlación reglas: >50 activas, tuned, false positive ratio <25%

BLOQUE V: RESPONDER (RS)

P5.1.1 - Plan de Respuesta a Incidentes

Norma	Artículo/ Requisito	Requisitos Específicos	Nivel ENS	Mapeo NIST CSF 2.0
NIST CSF 2.0	RS.PL-01	Plan respuesta incidentes; comunicación; escalonamiento	N/A	Respond – Response Planning
GDPR	Art. 33, 34	Notificación autoridad supervisora ≤72h; notificación afectados; comunicación plan	BÁSICA	Breach notification procedures
ENS	Plan de Respuesta	Plan incidentes escrito, actualizado, socializado; equipo designado	L2/L3	RS.PL-01 Incident response plan
NIS2	Art. 21	Protocolo notificación autoridades; plan respuesta; contactos establecidos	Obligatorio	Incident response & reporting
ISO 27001	A.17.1	Política incidentes; procedimientos, responsabilidades , contactos	Obligatorio	A.17 Incident Management

Evidencia Aceptable:

- ✓ Documento Plan Respuesta Incidentes v. actual (último 12 meses)
- ✓ Contiene: Definiciones, fases (prep, detection, analysis, containment, eradication, recovery, post), roles, escaladas
- ✓ Contactos de equipo: nombres, tlfes, emails (CISO, SOC Lead, Legal, PR, CEO)
- ✓ Checklists por tipo incidente (ransomware, phishing, DDoS, data breach)
- ✓ Procedimiento notificación: Autoridad Supervisora, afectados, requerimientos GDPR

P5.2.3 - MTDD y MTTR Reportados

Norma	Artículo/ Requisito	Requisitos Específicos	Nivel ENS	Mapeo NIST CSF 2.0
NIST CSF 2.0	DE.AE-01, RS.MI-03	Tiempo detección incidentes; tiempo remediación	N/A	Detect Anomalies; Respond Mitigate
NIS2	Art. 19	Evaluación de capacidad detectar y responder; reporte periódico	Obligatorio	Detection & response metrics
ISO 27001	A.17.2	Análisis y clasificación incidentes; evaluación respuesta	Obligatorio	A.17 Incident Management

Evidencia Aceptable:

- ✓ Dashboard/Reporte MTDD (ej: promedio 120 minutos; target <120)
- ✓ Dashboard/Reporte MTTR (ej: promedio 6 horas; target <4)
- ✓ Histórico últimos 12 incidentes con timestamps
- ✓ Desglose por tipo incidente (si es relevante)

BLOQUE VI: RECUPERAR (RC)

P6.1.1 - Plan de Continuidad de Negocio (BCP)

Norma	Artículo/ Requisito	Requisitos Específicos	Nivel ENS	Mapeo NIST CSF 2.0
NIST CSF 2.0	RC.PL-01, RC.PL-02	Plan recuperación; objetivos RTO/RPO; pruebas	N/A	Recover – Planning & Recovery
ENS	Plan Continuidad	BCP/DRP escrito, actualizado, practicado; RTO/RPO definidos	L3/L4	RC.PL-01 Restoration plan
NIS2	Art. 20	Capacidad recuperación servicios; comprobación funcionamiento	Obligatorio	Business continuity & recovery
ISO 27001	A.17.1	Plan continuidad información seguridad; pruebas periódicas	Obligatorio	A.17.2 Business continuity

Evidencia Aceptable:

- ✓ Documento BCP/DRP actual (último 12 meses)
- ✓ RTO definido por sistema crítico (ej: App X RTO <2 horas)
- ✓ RPO definido (ej: RPO <30 minutos datos financieros)
- ✓ Procedimientos restauración: paso a paso, responsables
- ✓ Contactos sitio alternativo, proveedor hosting, etc.
- ✓ Registro pruebas año actual: fecha, resultado, problemas encontrados

P6.1.3 - Backups 3-2-1

Norma	Artículo/ Requisito	Requisitos Específicos	Nivel ENS	Mapeo NIST CSF 2.0
NIST CSF 2.0	RC.CO-01, RC.CO-02	Copia de respaldo; restauración verificada	N/A	Recover – Restoration
GDPR	Art. 5, 32	Disponibilidad datos; protección integridad; backups	BÁSICA	Backup & restoration procedures
ENS	Protección ante Pérdida	Backups estrategia 3-2-1; copias inmutables; testeo restauración	L3/L4	RC.CO-01 Backup & restore
ISO 27001	A.12.3.1	Copia de respaldo información; medios protegidos	Obligatorio	A.12.3 Backup

Evidencia Aceptable:

- ✓ Política Backups documentada: frecuencia, retención, medios
- ✓ Implementación 3-2-1: 3 copias, 2 medios (ej. disk + tape), 1 offsite
- ✓ Logs de backups últimos 90 días: éxito/fallo, verificación integridad
- ✓ Test restauración completado año actual: fecha, resultado
- ✓ Almacenamiento offsite validado (ej. nube con cifrado, proveedor de confianza)

BLOQUE VII: ANÁLISIS DE VULNERABILIDADES

P7.1.1 - Escaneos de Vulnerabilidades Regulares

Norma	Artículo/ Requisito	Requisitos Específicos	Nivel ENS	Mapeo NIST CSF 2.0
NIST CSF 2.0	ID.RA-02, ID.RA-03	Evaluación vulnerabilidades; herramientas automatizadas	N/A	Identify & Assess Vulnerabilities
GDPR	Art. 32	Evaluación riesgos información; auditoría de seguridad	BÁSICA	Vulnerability assessment
ENS	Evaluación Vulnerabilidades	Evaluación vulnerabilidades regular; herramientas scanning; priorización CVSS	L3/L4	ID.RA-02 Scan for vulnerabilities
NIS2	Art. 19, 20	Evaluación vulnerabilidades; auditoría seguridad; penetration testing	Obligatorio	Regular vuln. assessments
ISO 27001	A.12.6.1	Cambios técnicos evaluados; vulnerabilidades conocidas; evaluación	Obligatorio	A.12.6 Change management

Evidencia Aceptable:

- ✓ Herramienta scanning (Nessus, Qualys, OpenVAS, etc.) en uso
- ✓ Calendario escaneos: mensual mínimo; semanal óptimo
- ✓ Reporte último escaneo: fecha, assets escaneados, vulnerabilidades encontradas
- ✓ CVSS scores asignados a cada hallazgo
- ✓ Plazo remediación por severidad: Crítica <24h, Alta <7 días, Media <30 días

P7.2.1 - Pruebas de Penetración Anuales

Norma	Artículo/ Requisito	Requisitos Específicos	Nivel ENS	Mapeo NIST CSF 2.0
NIST CSF 2.0	ID.RA-03	Evaluación de controles; pruebas de seguridad	N/A	Assess Cybersecurity Controls
GDPR	Art. 32	Medidas técnicas organizativas; auditoría de seguridad	BÁSICA	Penetration testing
ENS	Evaluación de Controles	Pentesting: anual obligatorio; externo recomendado; seguimiento hallazgos	L3/L4	ID.RA-03 Penetration testing
NIS2	Art. 20(1)	Pruebas intrusión, incluyendo web; auditoría externa	Obligatorio	Annual penetration testing
ISO 27001	A.14.2.1	Pruebas seguridad aplicaciones; evaluación código	Obligatorio	A.14 Software development

Evidencia Aceptable:

- ✓ Reporte Pentest año actual (interno o externo)
- ✓ Alcance claro: rango IP, aplicaciones web, phishing, social engineering
- ✓ Metodología: OWASP Top 10, PTES, u otra reconocida
- ✓ Vulnerabilidades encontradas: descripción, CVSS, recomendaciones
- ✓ Plan remediación: vulnerabilidades criticadas, plazos asignados
- ✓ Prueba post-remediación: hallazgos verificados como cerrados

BLOQUE VIII: SIEM

P8.1.1 - Cobertura de Fuentes SIEM

Norma	Artículo/ Requisito	Requisitos Específicos	Nivel ENS	Mapeo NIST CSF 2.0
NIST CSF 2.0	DE.AE-01, DE.CM-01	Monitoreo detecta anomalías; correlación de datos múltiples	N/A	Detect → Anomalies & Events
ENS	Monitoreo	Cobertura logs mínimo 80%; integración de múltiples fuentes	L3/L4	DE.AE-01 Network monitoring
NIS2	Art. 19	Monitoreo redes; detección intrusiones; trazabilidad acciones	Obligatorio	Security monitoring infrastructure

Evidencia Aceptable:

- ✓ Inventario fuentes conectadas: firewalls, WAF, IDS/IPS, endpoints, aplicaciones, AD/LDAP, etc.
- ✓ % cobertura: $(\text{Fuentes en SIEM} / \text{Total Fuentes}) \times 100 = \text{Target} > 85\%$
- ✓ Tiempo ingesta: logs recibidos <5 minutos after generation
- ✓ Validación: muestreo de logs en SIEM vs. fuente original (sample check)

BLOQUE IX: CAPACITACIÓN EN SEGURIDAD

P9.2.1 - Phishing Click Rate

Norma	Artículo/ Requisito	Requisitos Específicos	Nivel ENS	Mapeo NIST CSF 2.0
NIST CSF 2.0	PR.AT-01	Conciencia de amenazas; capacitación phishing	N/A	Protect → Awareness Training
GDPR	Art. 32(2)(c)	Capacitación seguridad información; conciencia amenazas	BÁSICA	Phishing awareness
ENS	Concienciación	Simulacros phishing; métricas de click rate; capacitación adaptativa	L3/L4	PR.AT-01 Phishing simulations
NIS2	Art. 20(2)	Conciencia ciberseguridad; capacitación phishing & social engineering	Obligatorio	Phishing awareness program

Evidencia Aceptable:

- ✓ Reporte simulacro phishing mes actual: fecha, # de empleados, # clicks, % click rate
- ✓ Histórico 6 meses: tendencia decreciente de click rate
- ✓ Target click rate: <5% (excelente), <10% (bueno), <20% (aceptable)
- ✓ Capacitación adaptativa: empleados con alto click rate reciben micro-training
- ✓ Report rate: % empleados que reportan proactivamente phishing simulado (target >30%)

TABLA RESUMEN: ALINEACIÓN PREGUNTAS → MARCOS NORMATIVOS

Pregunta	NIST CSF 2.0	ENS	NIS2	GDPR	ISO 27001
P1.1.1 Política	GV.PO-01	L2+	Art.17-18	Art.5,32	A.5.1
P1.1.2 CISO	GV.OC-01	L2+	Art.18	Art.37-38	A.6.1
P1.2.1 Eval. Riesgos	ID.RA-01, GV.RM-01	L3+	Art.19-20	Art.5(1)(f)	A.12.6
P2.1.1 CMDB	ID.AM-01	L3+	Art.19	Art.32	A.8.1
P3.1.1 MFA	PR.AC-01	L3/L4	Art.20	Art.32(b)	A.9.2
P3.1.3 Access Review	PR.AC-04	L2/L3	Art.19	Art.32	A.9.2.5
P3.2.1 Cifrado	PR.DS-02	L3/L4	Art.20	Art.32(1)(a)	A.10.1
P3.4.1 Capacitación	PR.AT-01	L2/L3	Art.20(2)	Art.32(2)(c)	A.6.2
P4.1.1 SIEM	DE.AE-01	L3/L4	Art.19,21	Art.32	A.12.4
P5.1.1 Plan Incidentes	RS.PL-01	L2/L3	Art.21	Art.33-34	A.17.1
P5.2.3 MTTD/MTTR	DE.AE-01, RS.MI-03	L3/L4	Art.19	Art.33	A.17.2
P6.1.1 BCP/DRP	RC.PL-01	L3/L4	Art.20	Art.5,32	A.17.1
P6.1.3 Backups	RC.CO-01	L3/L4	Art.20	Art.5,32	A.12.3
P7.1.1 Escaneo Vuln.	ID.RA-02	L3/L4	Art.19-20	Art.32	A.12.6
P7.2.1 Pentest	ID.RA-03	L3/L4	Art.20	Art.32	A.14.2
P8.1.1 SIEM Cobertura	DE.AE-01	L3/L4	Art.19	Art.32	A.12.4
P9.2.1 Phishing Click Rate	PR.AT-01	L3/L4	Art.20(2)	Art.32(2)(c)	A.6.2

Esta matriz permite validar que cada pregunta de encuesta mapea a requisitos normativos concretos, facilitando demostraciones de cumplimiento a reguladores y auditores.